

Pentesting a My File Server 1: riesgo crítico para la continuidad institucional

Evaluación ejecutiva para el Consejo de Administración

Autora: Karla Vanessa González Espinoza

Evaluador: Mtro. Servando López Contreras

Octubre 2026 · TLP: AMBER

Un ejercicio ético para anticiparnos al atacante

Medir la resistencia real del servidor central de archivos ante un adversario hostil.

Activo evaluado

My File Server 1

IP 10.0.2.5

CentOS Linux 7

Estación auditora Red Team

Kali Linux

10.0.2.3

Enfoque preventivo: sin ataques de denegación de servicio ni ingeniería social al personal.

Cinco fases bajo estándares reconocidos

Metodología PTES con guías OWASP para servicios expuestos.



Reconocimiento

Identificar la superficie expuesta.



Enumeración

Precisar servicios y accesos.



Explotación inicial

Validar una vía de entrada.



Escalada de privilegios

Comprobar el control obtenido.



Análisis de impacto

Traducir evidencia a riesgo.

Secuencia de trabajo de izquierda a derecha. Las dos fases centrales materializaron el compromiso.

Veredicto: riesgo crítico, compromiso total en dos fases



RIESGO CRÍTICO

<30

minutos

Tiempo de compromiso

root

Superusuario

Acceso obtenido

4

Vectores abiertos

web, FTP, SMB y SSH

La explotación inicial y la escalada de privilegios llevaron al control total del servidor.

Tres eslabones rotos permitieron la intrusión total

01

Credenciales expuestas

Credenciales en texto plano publicadas en la web (readme.txt).

02

Acceso remoto habilitado

Servicio de transferencia FTP sin confinamiento, que admitió inyectar una llave de acceso remoto.

03

Control completo

Sistema base sin parches, vulnerable a DirtyCOW (CVE-2016-5195).

La combinación de fallas convirtió una exposición pública en control de superusuario.

Un atacante real pondría en jaque la operación

Fuga de información

Fuga masiva de documentos confidenciales.

Interrupción institucional

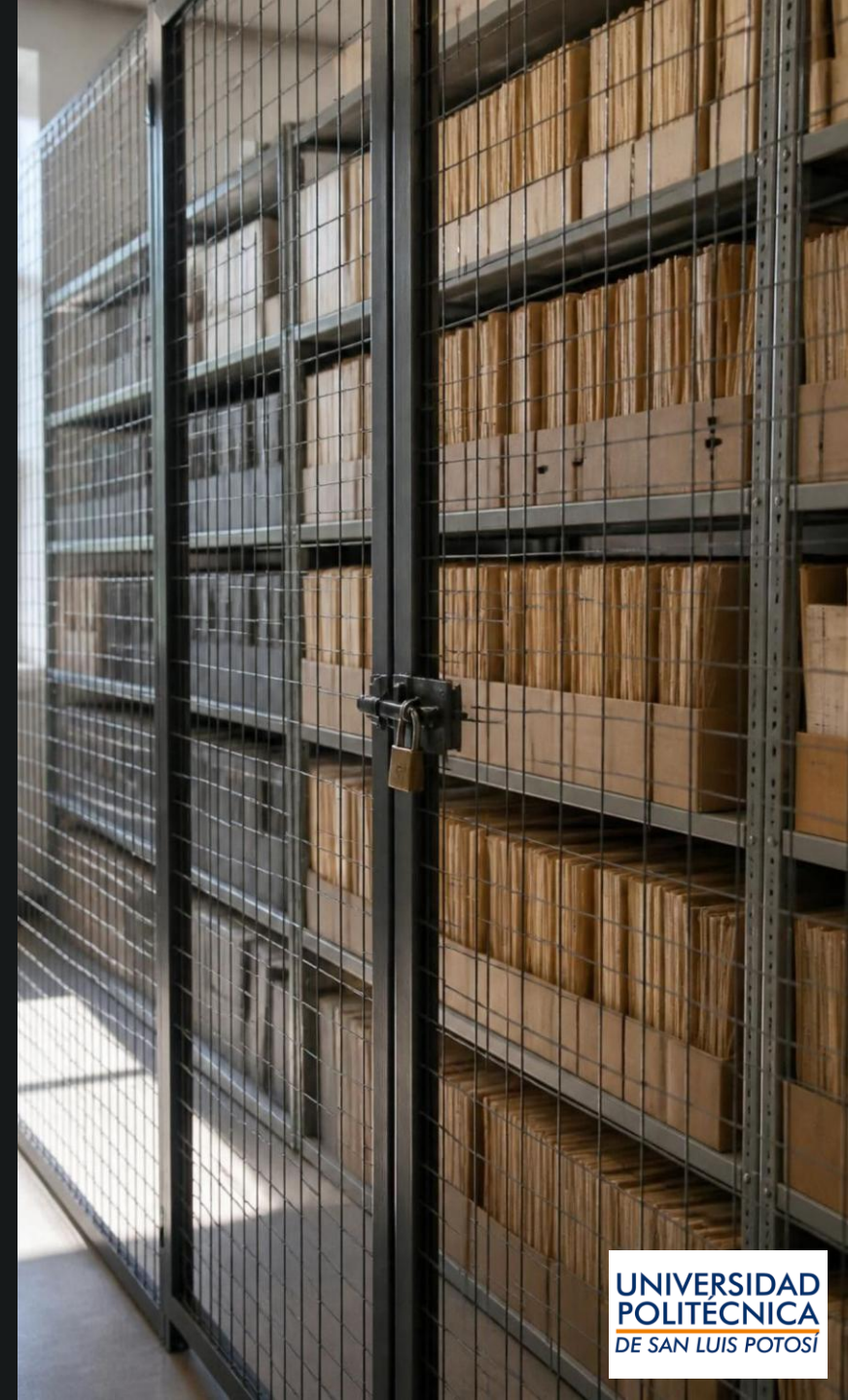
Paralización de operaciones académicas y administrativas.

Secuestro de archivos

Secuestro de archivos por ransomware.

Expansión del ataque

El servidor serviría de pivote hacia el resto de la red.



Confidencialidad, integridad y disponibilidad: las tres en nivel crítico

CONFIDENCIALIDAD	INTEGRIDAD	DISPONIBILIDAD			
				100% comprometido	100% comprometido
Visibilidad total de datos departamentales, claves y contraseñas.	Capacidad de alterar información y borrar evidencias.	Control para detener servicios o cifrar datos.			

El 100% expresa alcance de control sobre el activo evaluado; no cuantifica documentos filtrados ni daños ejecutados.

Todos los hallazgos caen en la zona roja

Probabilidad muy alta frente a impacto catastrófico.

PROBABILIDAD ↓ IMPACTO →	MÍNIMO	MENOR	MODERADO	MAYOR	CATASTRÓFIC O
Muy alta				FTP Servicios	Claves Kernel
Alta				—	—
Media				—	—
Baja				—	—
Muy baja				—	—

Atención inmediata

Credenciales expuestas y kernel sin parchar.

Prioridad relativa alta y media

FTP sin confinamiento y servicios redundantes, dentro de una exposición global crítica.

Matriz 5×5 cualitativa. Ubicación orientativa para priorizar; el reporte no aporta puntuaciones por celda.

La causa raíz es de gestión, no de tecnología

Despliegue sin endurecimiento

Falta de endurecimiento (hardening) antes del despliegue.

Mantenimiento sin continuidad

Ausencia de gestión periódica de parches.

Exposición innecesaria

Duplicidad innecesaria de servicios de red: dos servidores FTP, Samba y NFS.

La corrección debe incorporar responsables, revisiones periódicas y evidencia de cumplimiento.

Dos tiempos de acción: contener en 48 horas, estructurar en 4 semanas

0 a 48 h · Contener

- Retirar credenciales de la web.
- Restringir FTP.
- Actualizar el kernel.

1 a 4 semanas · Estructurar

- Apagar servicios redundantes.
- Segmentar con firewall.
- Exigir contraseñas robustas.

Asignar responsables y verificar las correcciones mediante una nueva prueba.

Costos: por confirmar · ROI: por confirmar